

Security+ 2.3 · Supply Chain Vulnerabilities

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · **Aula 2.3 — Supply Chain Vulnerabilities (9:12)** · [Vídeo Oficial no YouTube ↗](#) · [Página no Professor Messer ↗](#)

Resumo Executivo da Aula: Atacar o ELO que tu confias: software comprometido (SolarWinds), componente de terceiros, chip de hardware malicioso, library de código (npm/pip), open-source package sem dono claro. O atacante injeta código no CANAL CONFIÁVEL — todo mundo baixa espalha pra ele. Defesa: SBOM (lista de ingredientes), code signing, SCA (checa vulnerabilidade em library), verificação de fonte.

Highlights que a prova cobra

- Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar
- SolarWinds: o caso clássico (18k empresas)
- SBOM = Software Bill of Materials — lista de componentes do software

Dicas de prova & Cenários Típicos

- 'list of software components' = SBOM
- 'checks dependencies for known vulnerabilities' = SCA

Cenário clássico de exame: Cenário: 'library de npm comprometida afeta todo mundo que usa o pacote' = supply chain vulnerability.

🔔 Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e Armadilhas da Aula 2.3 — Supply Chain Vulnerabilities)

Por que este aprofundamento é cobrado no exame? O vídeo do Professor Messer apresenta uma introdução ágil. Porém, a banca oficial CompTIA Security+ (SY0-701) exige raciocínio de engenharia prática e cobra diretamente os seguintes protocolos, jargões e ferramentas no contexto desta aula:

- **Princípio do Menor Privilégio:** Usuários e sistemas devem ter apenas as permissões estritamente necessárias para suas funções corporativas.
- **Defesa em Profundidade (Defense-in-Depth):** Aplicação de múltiplas camadas de controles (técnicos, administrativos, físicos) para evitar que a falha de um exponha todo o ambiente.

⚠️ Armadilhas e Pegadinhas Clássicas da Banca:

- Nunca decore apenas letras ou siglas: a CompTIA altera o cenário exigindo que você justifique por que o controle escolhido é o *MAIS adequado* dentre 4 opções válidas.
- Fique atento às restrições do enunciado: 'sem custo adicional' favorece configurações nativas do SO; 'maior granularidade de rede' favorece TACACS+ em vez de RADIUS; 'não-repúdio' exige chave privada/assinatura digital.

✅ Perguntas de treino comentadas (10 questões)

Gabarito com resolução passo a passo e análise técnica individual de cada distrator no fim. Tente responder antes de olhar.

1. Comprometer um fornecedor de software pra atingir todos os clientes dele (ex: SolarWinds):

- A)** Ataque de cadeia de suprimentos
- B)** Watering hole
- C)** Insider
- D)** Zero-day

2. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar...

3. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'SolarWinds: o caso clássico (18k empresas)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: SolarWinds: o caso clássico (18k empresas)...

4. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'SBOM = Software Bill of Materials — lista de componentes do software'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: SBOM = Software Bill of Materials — lista de componentes do software...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'list of software components' = SBOM'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'list of software components' = SBOM...

6. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'checks dependencies for known vulnerabilities' = SCA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'checks dependencies for known vulnerabilities' = SCA...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Cenário: 'library de npm comprometida afeta todo mundo que usa o pacote' = supply chain vulnerability.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Cenário: 'library de npm comprometida afeta todo mundo que usa o pacote' = ...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'SolarWinds: o caso clássico (18k empresas)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: SolarWinds: o caso clássico (18k empresas)...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Supply Chain Vulnerabilities): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.3), um analista avalia o seguinte requisito técnico: 'SBOM = Software Bill of Materials — lista de componentes do software'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: SBOM = Software Bill of Materials — lista de componentes do software...

GABARITO COMENTADO COM ANÁLISE DETALHADA DOS DISTRATORES

1) A — Ataque de cadeia de suprimentos.

✓ **Por que está certa:** Ataque de cadeia de suprimentos (supply chain attack) ocorre quando um adversário compromete um fornecedor, parceiro ou componente de software/hardware para atingir os clientes finais desse fornecedor. No caso SolarWinds (2020), atacantes comprometeram o processo de build do software Orion, inserindo código malicioso que foi distribuído como atualização legítima a milhares de clientes, incluindo agências governamentais. Esse é o exemplo clássico de ataque à cadeia de suprimentos, conforme descrito no objetivo SY0-701 2.2 (ameaças à cadeia de suprimentos) e 2.3 (vetores de ataque). A questão descreve exatamente esse cenário: comprometer um fornecedor de software para atingir todos os clientes dele.

✗ **Por que as outras estão erradas:**

- *Watering hole:* Watering hole é um ataque em que o adversário compromete um site legítimo frequentado por um grupo específico de vítimas (ex.: site de um setor industrial) e insere código malicioso para infectar os visitantes. O objetivo é atingir usuários que visitam aquele site, não comprometer um fornecedor de software para distribuir malware a todos os seus clientes. No watering hole, o vetor é o site de terceiros visitado pelas vítimas; na cadeia de suprimentos, o vetor é o próprio produto ou atualização do fornecedor. A questão fala em comprometer um fornecedor de software para atingir todos os clientes dele, o que é supply chain, não watering hole.
- *Insider:* Ameaça interna (insider threat) refere-se a um indivíduo com acesso autorizado (funcionário, contratado, parceiro) que usa esse acesso para causar dano, roubar dados ou facilitar ataques. O atacante é interno à organização, não um fornecedor externo comprometido. No caso SolarWinds, os atacantes eram externos (APT29) que comprometeram a cadeia de suprimentos da SolarWinds; não se trata de um insider da SolarWinds ou dos clientes. Portanto, insider não descreve o cenário de comprometer um fornecedor para atingir seus clientes.
- *Zero-day:* Zero-day refere-se a uma vulnerabilidade desconhecida pelo fornecedor, para a qual não há patch disponível. O ataque explora essa falha antes que seja corrigida. Embora ataques à cadeia de suprimentos possam envolver zero-days, o conceito de zero-day é sobre a natureza da vulnerabilidade, não sobre o vetor de comprometer um fornecedor para atingir clientes. No caso SolarWinds, o ataque não dependeu exclusivamente de uma zero-day; envolveu comprometimento do processo de build e distribuição de atualização maliciosa. A questão pede o nome do ataque que compromete um fornecedor para atingir todos os clientes, que é supply chain, não zero-day.

2) D — Implementar a solução correspondente: Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

3) D — Implementar a solução correspondente: SolarWinds: o caso clássico (18k empresas)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): SolarWinds: o caso clássico (18k empresas).

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

4) A — Implementar a solução correspondente: SBOM = Software Bill of Materials — lista de componentes do software....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): SBOM = Software Bill of Materials — lista de componentes do software.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

5) D — Implementar a solução correspondente: 'list of software components' = SBOM....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): 'list of software components' = SBOM.

✗ Por que as outras estão erradas:

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

6) A — Implementar a solução correspondente: 'checks dependencies for known vulnerabilities' = SCA....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): 'checks dependencies for known vulnerabilities' = SCA.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

7) C — Implementar a solução correspondente: Cenário: 'library de npm comprometida afeta todo mundo que usa o pacote' =

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): Cenário: 'library de npm comprometida afeta todo mundo que usa o pacote' = supply chain vulnerability..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

8) B — Implementar a solução correspondente: Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): Supply chain: o atacante usa o CANAL CONFIÁVEL pra entrar.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

9) C — Implementar a solução correspondente: SolarWinds: o caso clássico (18k empresas)....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): SolarWinds: o caso clássico (18k empresas).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

10) D — Implementar a solução correspondente: SBOM = Software Bill of Materials — lista de componentes do software....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.3 (Supply Chain Vulnerabilities): SBOM = Software Bill of Materials — lista de componentes do software.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.